ACC-05 · Account Lockout Triage & Repeat-Incident Escalation

How to tell apart the five different things people report as “locked out”, and what happens when the same account comes back.

Field	Value
Document ID	ACC-05
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 1 — the Service Desk. Escalates to Tier 2 Account Services, which holds the directory permissions.
Review cycle	Every six months while you are changing identity platforms, then annually.

1. Purpose

“I’m locked out” is a symptom with at least five distinct causes. Each has a different fix, and treating them all as a password reset is how a modest number of genuine lockouts turns into a lockout category twice its size.

This document gives Tier 1 a decision path that identifies the cause before anything is changed, and gives the department a ladder for the account that keeps coming back.

> **Check your own directory before trusting the decision path**
>
> Read your password and lockout policies before you assume anything. A group policy with a lockout threshold of 0 disables lockout entirely for the people it covers, so their “lockout” is coming from somewhere else: cloud smart lockout, a separate sign-in service, or an expired password experienced as a lockout.
>
> Check the maximum password age too. A value that expires passwords far sooner than intended will fill the desk with “lockouts” that are really expiry, arriving under the wrong name.
>
> Until you have confirmed both, record which population the caller belongs to on every lockout ticket. That single field settles the question faster than any investigation.

> **The most expensive mistake in this category**
>
> Resetting a password that was never the problem. It consumes the contact, does not restore access, destroys the diagnostic trail, and the person calls back — so one ticket becomes two and the cause is now harder to find.
>
> Every step in §3 therefore starts with confirming the cause rather than acting on the symptom.

2. The five causes, and how to tell them apart

Cause	How it presents	Confirm by	Frequency
A — On-premises AD lockout	Fails immediately, everywhere, including on site. Often started overnight.	AD account lockout flag and bad-password count.	Common. Usually a stale credential somewhere, not the person typing wrong.
B — Entra smart lockout	Fails from one location, network or client but works from another.	Entra sign-in logs show the smart-lockout result and the source IP.	Common, and frequently a signal rather than a fault (§4 and ACC-03 §10).
C — MFA method unavailable	Password is accepted, then the second factor never arrives, or the app has no account in it.	Ask what changed about their phone. Almost always a new, reset or traded-in device.	Very common. Not a lockout at all.
D — Conditional Access or risk block	A specific policy or compliance message, or failure only from one device, network or app.	Entra sign-in log names the policy or the risk detection.	Rising as Conditional Access is deployed. Will rise further (ACC-03 §11).
E — Not a lockout	Sign-in succeeds; one application or portal denies access.	Check licence assignment, group membership, then the application.	Common and frequently misfiled.

Three questions separate almost all of them, and none requires an admin centre: does it fail everywhere or only in one place; is the password accepted before it fails; and did anything change about their phone. Appendix A is that sequence as a card.

3. Cause by cause — what to do

A — On-premises AD lockout

1. Confirm the lockout flag. Do not reset the password — the password is probably fine.
2. Escalate to Tier 2 to unlock. Tier 1 cannot unlock in Entra or AD.
3. Then find the source, which is the part that stops it recurring. A stale credential on a phone mail client, a mapped drive with a saved old password, or a scheduled task is the usual culprit. An account that locks out again within hours has a machine doing it, not a person.
4. Record the source when found. A pattern across several accounts is a Tier 3 matter.

B — Entra smart lockout

1. Read the sign-in log: how many failures, from where, against what.

2. Where the source is the person's own location, wait out the lockout or have Tier 2 clear it, then address whatever is retrying.
3. Where the source is an unfamiliar IP or country, stop treating this as a lockout. It is a possible compromise — go to ACC-03 §10 and notify Tier 3.

C — MFA method unavailable

1. Do not reset the password. It is not broken and resetting it adds a second problem.
2. Verify identity per ACC-06. This is the case most often exploited, because "I have a new phone" is entirely plausible and requires no story.
3. Escalate to Tier 2 for method re-registration, or a Temporary Access Pass where every method is gone (ACC-03 §5.4).
4. Before closing, get a second method registered. This case is almost always a person who had only one.

D — Conditional Access or risk block

1. Read the policy name or risk detection in the sign-in log. The log says why; guessing wastes the contact.
2. Resolve the condition — device compliance, location, app, or risk state. A reset will not clear it and will mask the cause.
3. Where the block is a device compliance failure, this is a device matter (DEV-02), not an account one.
4. Where the same policy blocks several people in a day, escalate to Tier 3 immediately. That is a misconfiguration, not five user problems (ACC-03 §11).

E — Not a lockout

1. Reclassify the ticket. The category matters for measurement and travels with the ticket on escalation.
2. Check licence (M365-20), then group membership (M365-04), then the application itself (ACC-16).

---

4. The one that looks like a lockout and is not

> **"Somebody else has been logging into my account"**
>
> Do not reset the password and close it. That destroys the evidence and does not answer the question.
>
> It opens at Tier 2. The evidence has to distinguish genuine credential sharing from a person travelling with their own device — those look identical in a sign-in log alone, and getting it wrong in either direction is serious.
>
> It reaches HR, or whoever handles conduct for that population, on a real pattern, not a single event. The tier tells you who looks; the evidence tells you how far it goes.

5. Repeat-incident escalation

Picture an account blocked for the third time in a few months. Good handling looks like this: brief the person, then notify their manager and whoever owns security. This section makes that a standing ladder so it does not depend on who picks up the ticket.

Occurrence	Action	Decides	Recorded
1st	Restore per §3. Record the confirmed cause. Brief the person on credential sharing (ACC-15). Get a second MFA method registered.	Tier 1	Ticket
2nd within 90 days	Restore, then review sign-in history for shared-credential or unfamiliar-location patterns. Require re-registration of all MFA methods. Flag for watch.	Tier 1, Tier 2 informed	Ticket + watch list
3rd within 90 days	Treat as suspected compromise or sharing until shown otherwise. Force reset, revoke all sessions, remove and re-register every method. Notify the person's manager in writing.	Tier 3 decides; Tier 4 informed	Ticket + security record
Confirmed sharing or sale of credentials	Suspend per ACC-13. Refer to HR, or whoever handles conduct for that population. Do not restore until the referral concludes.	Tier 4 approves	Security record + referral
Confirmed third-party compromise	Declare an incident under GOV-03. Preserve sign-in and mailbox audit data before remediating.	Tier 4 declares	Incident record

Two cautions. A repeat count is not evidence of wrongdoing — a person with one MFA method and an unreliable phone will legitimately appear three times, and treating them as a suspect is both wrong and corrosive. And the count is per 90 days rather than per lifetime, so someone who had trouble a year ago does not carry it forever.

6. Escalating properly

The governing rule: escalation changes the tier, not the queue. The category and the full history travel with the ticket, and nobody starts over.

- Set the escalation category and add owner's notes: what the person reported, what you tried, what you confirmed about their identity, and which of the five causes you established.
- Tier 2 picks it up under Account Services, which holds the directory permissions. Tier 2 may recategorise after review, including back into a Tier 1 subcategory.
- Escalate on scope, not difficulty. A fiddly case still inside Tier 1's remit stays with Tier 1 — ask in the Tier 1+2 channel rather than moving the ticket.
- Never escalate without a confirmed cause from §2, or with "user is locked out" as the whole description. That forces Tier 2 to redo the triage.

7. Recording — the required field

> **Every lockout ticket records its confirmed cause: A, B, C, D or E.**
>
> This single field is what turns an undifferentiated pile of lockouts into a ranked list of fixable root causes. Without it the number can move around but cannot come down, because nobody knows which cause dominates.
>
> The prediction worth testing: cause C — a phone that changed — will turn out to be a large share of what is currently filed as lockouts, and its fix is not password policy at all. It is getting a second MFA method registered on every account (ACC-03 §5.1, ACC-04 §7).

8. Service levels

Activity	Commitment (per GOV-06)
Triage to a confirmed cause	Within the first contact. This is Tier 1's core work, not a queued task.
Unlock after escalation, identity verified	P2 — acknowledged within 4 coverage hours.
MFA re-registration	P2 at Tier 2.
Suspected compromise (§4, or 3rd occurrence)	P1 — escalated to Tier 3 within 30 minutes.
Same Conditional Access policy blocking several people	P1 at Tier 3. This is an outage in miniature.

9. Measurement

- Lockout tickets per week by confirmed cause. The whole point of §7.
- Share resolved at Tier 1 without escalation, before and after the ACC-04 §6 read-only visibility decision.
- Repeat rate: accounts appearing twice or more in 90 days.
- Accounts with fewer than two MFA methods. The leading indicator for cause C.
- Cause-A recurrence within 24 hours — the signal that the stale credential was never found.

10. Records

Record	Held in	Retention
Confirmed cause A–E	Ticket — required field	3 years
ACC-06 verification tier	Ticket — required field	3 years
Cause-A source, when found	Ticket	3 years
Repeat-incident watch list	Tier 3 security record	Rolling 12 months
Manager notifications	Security record	3 years

11. Related documents

ID	Title	Relationship
ACC-03	MFA Enrollment, Reset & Account Recovery	Summarises this triage at §8; owns risky sign-in handling and the phishing-resistant rollout.
ACC-04	Password Standard & Self-Service Password Reset	The path that prevents most of cause C ever reaching the desk.
ACC-06	Identity Verification Before Any Account Action	Mandatory before any restoration.
ACC-13	Account Suspension for Misuse	Where the §5 confirmed-sharing path leads.
ACC-15	Acceptable Use & Credential-Sharing Standard	The published rule §5 briefs people against.
DEV-02	Device Compliance & Configuration Baseline	Cause D is frequently a device matter.
GOV-03	Security Incident Response & Escalation Matrix	Where §4 and the third occurrence escalate.
GOV-06	Service Commitments, Priority & Escalation	Supplies §8.

Appendix A — Triage card

Three questions identify almost every case. Establish the cause before changing anything.

	Ask	If yes
1	Does it fail everywhere, immediately, including on site?	Cause A — AD lockout. Escalate to unlock, then hunt the stale credential.
2	Does it work from somewhere else, or on another device?	Cause B — smart lockout. Read the source IP. Unfamiliar → ACC-03 §10.
3	Is the password accepted, and then the second factor never arrives?	Cause C — MFA method. Do NOT reset. Verify per ACC-06, escalate for re-registration.
4	Did they get a specific policy or compliance message?	Cause D — Conditional Access. Read the log; fix the condition, not the password.
5	Does sign-in succeed, but one app denies them?	Cause E — not a lockout. Reclassify: licence, group, or application.
6	Are they saying somebody else has been signing in?	Go to §4. Do not reset. Tier 2 first.
7	Has this account been here before in the last 90 days?	Go to Appendix B before restoring.

Appendix B — Repeat-incident ladder card

Time	Do	Tell
1st	Restore. Record cause. Brief on credential sharing. Register a second MFA method.	Nobody beyond the ticket.
2nd in 90 days	Restore. Review sign-in history. Re-register all methods. Flag for watch.	Tier 2.
3rd in 90 days	Treat as suspected compromise. Force reset, revoke sessions, re-register everything.	Their manager, in writing. Tier 3 decides; Tier 4 informed.
Sharing confirmed	Suspend per ACC-13. Do not restore pending referral.	HR, or whoever handles conduct. Tier 4 approves.
Compromise confirmed	Preserve audit data BEFORE remediating. Declare under GOV-03.	Tier 4 declares the incident.

A repeat count is not evidence of wrongdoing. Somebody with one MFA method and an unreliable phone will legitimately appear three times. Establish the cause each time before you draw a conclusion about the person.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.